

积木仓 BlockHub 信息安全白皮书

企业评估版 · 数据驻留 · 传输与静态加密 · 访问控制 · 删除承诺

对外可控分发 · 供采购 / 安全 / 合规评估 · 版本 2026-07-16

置信度说明：本文档基于积木仓 BlockHub 当前产品设计及安全控制措施编写，适用于企业评估场景。所有指标均为参考值，具体以合同约定为准。

1. 文档目的与适用范围

本白皮书面向企业采购、安全与合规评估团队，系统阐述积木仓 BlockHub（企业智能应用 PaaS，选型即交付，Web+App）在数据驻留、传输与静态加密、访问控制、审计、删除等维度的安全能力与承诺。文档内容基于产品当前版本（2026.07）的设计与实测，旨在为评估方提供可核验的技术与流程依据。

适用范围包括：企业客户在采购决策阶段对 BlockHub 平台进行安全审查；已签约客户在合同期内对安全控制措施的持续验证；第三方审计机构对平台安全合规性的独立评估。文档中提及的指标（如加密算法、密钥长度、响应时间等）均为参考值，实际服务等级以双方签署的合同及服务等级协议（SLA）为准。

2. 数据驻留与出境控制

BlockHub 采用区域化数据存储架构，所有客户数据（包括应用配置、业务数据、用户身份信息）默认存储于客户所选地理区域内的数据中心。目前支持的区域包括：中国大陆（北京、上海、深圳）、亚太（新加坡）、欧洲（法兰克福）及北美（弗吉尼亚）。客户可在服务开通时指定数据驻留区域，平台确保数据不会自动迁移至其他区域。

数据出境需经客户明确书面授权，且仅发生在以下场景：客户主动发起跨区域应用部署（如将应用从新加坡迁移至法兰克福）；或为满足灾难恢复需求，经客户同意后临时复制数据至备用区域（备用区域与主区域同属一个地理政治区域，如欧盟境内）。所有出境操作均记录在审计日志中，客户可通过管理控制台实时查看。平台不依赖第三方云服务商进行数据存储，所有数据中心由 BlockHub 直接运营或通过经认证的托管伙伴管理。

3. 传输安全与静态加密

所有客户端与 BlockHub 服务之间的通信均强制采用 TLS 1.2 及以上协议，支持前向保密（Perfect Forward Secrecy）的密码套件（如 ECDHE-RSA-AES256-GCM-SHA384）。API 端点、Web 控制台及移动 App 均启用 HTTPS，证书由公共可信 CA 签发，密钥长度至少 2048 位。内部服务间通信同样使用 mTLS 进行双向认证与加密。

静态数据加密采用 AES-256 算法，密钥由硬件安全模块（HSM）或云密钥管理服务（KMS）生成与存储，每个客户租户使用独立的数据加密密钥（DEK），且 DEK 定期轮换（默认每 90 天，可配置）。备份数据同样加密存储，加密密钥与主数据密钥分离。平台不存储客户明文密码，密码通过 bcrypt（成本因子 12）或 Argon2id 进行哈希处理。所有加密算法与密钥长度均为行业标准，具体实现细节可应客户要求提供第三方渗透测试报告。

4. 身份、权限与多租户隔离

BlockHub 支持企业身份联邦（SAML 2.0、OIDC、LDAP）及本地账户两种认证方式。多因素认证（MFA）为可选功能，推荐管理员及高权限用户启用。权限模型基于 RBAC（基于角色的访问控制），预定义角色包括：超级管理员、应用管理员、安全审计员、普通用户等，客户可自定义角色并细粒度分配权限（如只读、读写、管理）。

多租户隔离通过以下三层实现：网络层——每个租户分配独立的虚拟网络（VPC/VNet）及防火墙规则；数据层——所有数据库表包含租户 ID 字段，查询强制过滤，且使用行级安全策略（RLS）；应用层——会话 token 绑定租户标识，API 网关校验租户上下文。平台定期（每季度）进行租户隔离渗透测试，测试报告可应客户要求提供摘要版本。

5. 审计、留存与事件响应

平台记录所有管理操作、数据访问、权限变更及登录尝试，审计日志包含时间戳、操作者身份、源 IP、操作类型及结果。日志存储于独立于业务数据库的日志系统，保留期限默认为 365 天（可配置为 90 天至 730 天）。客户可通过管理控制台或 API 导出审计日志，格式为 JSON 或 CSV。

安全事件响应遵循内部定义的流程：发现事件后 15 分钟内启动初步分析，1 小时内通知客户安全联系人（若事件涉及客户数据），4 小时内提供初步影响评估，24 小时内更新事件状态。平台设有 7×24 安全运营中心（SOC），负责监控

异常行为、入侵检测及漏洞扫描。事件响应时间目标（TTR）为参考值，具体 SLA 以合同为准。

6. 删除、退出与证明材料

客户可随时通过管理控制台发起数据删除请求，支持按应用、按用户或全租户删除。删除操作执行后，数据在 30 天内从在线存储中移除，并在 90 天内完成所有备份的覆盖或销毁。删除完成后，平台向客户提供书面确认函（含删除时间戳及操作人）。

客户退出服务时，平台提供 30 天数据导出窗口（支持 JSON、CSV、SQL 转储），之后执行全租户删除。平台保留删除日志至少 180 天，以备合规审计。证明材料包括：SOC 2 Type II 报告（每年更新）、ISO 27001 认证、渗透测试报告（每季度）、数据删除确认函模板。所有材料可通过客户门户或安全团队直接索取。

7. 客户可验证的证据清单

为便于客户独立验证本白皮书所述控制措施，BlockHub 提供以下证据：1) 第三方渗透测试报告摘要（每季度，覆盖 Web 应用、API、基础设施）；2) SOC 2 Type II 报告（年度，含控制描述与测试结果）；3) ISO 27001 认证证书（当前有效）；4) 数据驻留区域列表及数据中心认证（如 SOC、ISO、PCI DSS）；5) 加密算法与密钥管理文档（含 HSM/KMS 配置）；6) 审计日志样本（脱敏后）；7) 数据删除确认函模板。

客户可通过以下方式获取上述材料：登录 BlockHub 管理控制台 -> 安全中心 -> 合规文档；或联系客户成功经理（CSM）签署保密协议后获取完整版本。平台同时支持客户或客户指定的第三方审计机构进行现场或远程审计，审计范围与时间需提前 30 天协商。

获取盖章版 / 完整问卷 / 定制差距分析：访问 blockhub.club 预约演示，或联系客户成功经理。